

## Assignment Overview

In this assignment, you will implement and evaluate identity-aware access controls for a containerized web application using a provided local lab scaffold. The goal is not merely to follow a setup procedure, but to apply Zero Trust and identity management principles to a web architecture, observe how the controls affect system behavior, and justify your conclusions using AAA and CI4A analysis.

You will configure the environment, test the application before and after identity-aware protections are applied, and submit a concise analysis showing:

1. what asset or route was exposed,
2. how trust boundaries were defined,
3. what authentication and authorization controls were applied,
4. what evidence was captured, and
5. what residual risks remain.

## Assignment Objectives

Upon completing this assignment, the student will be able to:

1. Analyze the trust assumptions of a containerized web application and identify exposed assets or routes.
2. Apply identity-aware controls to a web architecture using a reverse proxy and an identity layer.
3. Explain how authentication, authorization, and accounting are implemented in the lab environment.
4. Relate the implemented controls to CI4A security analysis.
5. Evaluate the effectiveness and limitations of the resulting design using evidence from observed system behavior.

## Student Task

You are given guidance to set up a containerized web application stack and a local identity management scaffold. Your task is to use this environment to evaluate how identity-aware controls change the security posture of the application.

You must:

# JHU WebSec Identity Management and Zero Trust Assignment

- bring up the environment using the provided scaffold,
- identify at least one sensitive or administrative path that requires stronger protection,
- implement the provided identity-aware control path,
- demonstrate the resulting behavior with evidence,
- explain the security value and limitations of the implemented design.

You are not expected to build an enterprise Identity Management platform from scratch. You are expected to reason clearly about trust boundaries, control placement, route protection, and evidence.

## **Student planning breakdown estimate 2.5 to 3 hours depending on your familiarity with Docker, Linux, and troubleshooting local web stacks:**

- Environment setup and configuration: 60 to 120 minutes
- Testing routes, MFA, and behavior changes: 20 to 40 minutes
- Capturing screenshots or logs and annotating them: 20 to 30 minutes
- Writing the 1.5-to-2.5-page report: 30 to 60 minutes
- It will go longer if you try to troubleshoot environment issues alone for too long, so if you run into issues, post them on the troubleshooting channel.

## **Required Submission Format**

Submit a concise report, approximately 1.5 to 2.5 pages, excluding screenshots and appendices, with the following sections:

### **1. Environment Summary, about 1 short paragraph**

Briefly describe the stack and identify what route or function was exposed before the control was added.

Possible aspects to Include:

- reverse proxy
- identity layer
- containerized application
- certificate or TLS support
- MFA mechanism

**Suggested length:** 4 to 6 sentences

### **2. Initial Exposure and Trust Assumptions, about 1 short paragraph**

Identify the application asset, route, or function being protected.

Consider explaining aspects such as:

- what was exposed before controls were added
- what trust assumption existed in the original design
- why that assumption was weak from a Zero Trust perspective

**Suggested length:** 4 to 6 sentences

### 3. Identity and Access Design, about 1 to 2 short paragraphs

Explain how your design applies identity-aware protection to the application.

Possible aspects to address:

- how authentication is handled
- how MFA is used
- how route protection is enforced
- whether any path, role, or privilege distinctions are present

**Suggested length:** 6 to 10 sentences

### 4. Evidence and Observed Behavior, mostly screenshots with brief captions

Provide annotated screenshots or logs that demonstrate the system behavior.

Include evidence of:

- successful access to the intended route
- denied or redirected access to a protected route
- MFA or identity verification occurring
- the change in /ghost path behavior before and after the added restriction

For each screenshot or log, add a **1 to 2 sentence caption** explaining what it proves.

**Suggested length:** Primarily figures and captions, minimal prose

### 5. AAA and CI4A Analysis, 1 short paragraph

Briefly explain how your implementation changes the security posture of the system.

Aspects to address:

# JHU WebSec Identity Management and Zero Trust Assignment

- Authentication
- Authorization
- Accounting
- Confidentiality
- Integrity
- Accountability or Assurance

Do not just define the terms. Explain how your specific design improved them, or where improvement remains limited.

**Suggested length:** 5 to 10 sentences

## 6. Residual Risk and Improvement, about 1 short paragraph

Identify **two** remaining weaknesses, limitations, or missing signals in the design.

Possible examples:

- reliance on local-only identity data
- lack of device posture checking
- lack of continuous session reevaluation
- bypass risk if upstream exposure remains
- limited accounting visibility
- another relevant weakness you observed

For each one, explain:

- why it matters
- one improvement you would recommend

**Suggested length:** 5 to 8 sentences total

## 7. Focused Analysis Question, about 1 short paragraph

Choose **one** of the questions below and answer it directly.

1. Where is the trust boundary in your design?
2. What changes when the identity layer is placed in front of the application?
3. What happens after the /ghost restriction is applied, and why does that matter from a Zero Trust perspective?
4. What important identity signal is still missing from this lab environment??

**Suggested length:** 3 to 5 sentences

## Submission Checklist

Before submitting, make sure your report includes:

- all 7 required section headings
- concise written responses
- annotated screenshots or logs
- evidence of both allowed and denied behavior
- explanation of what changed and why it matters
- two residual risks with suggested improvements

**Important Note:** This assignment is not graded as a checklist of interface clicks. The provided scaffold is intended to help you stand up a working environment quickly so that you can focus on security reasoning.

A successful submission must show that you understand:

- what was exposed,
- what control was added,
- where the trust boundary sits,
- what evidence shows the control is functioning,
- and what risks remain.

In other words, do not merely show that the lab works. Show why the design matters.

## Implementation Scaffold

Use the following scaffold to build the local lab environment. You may follow these steps directly or adapt them if you understand what you are changing. The purpose of the scaffold is to reduce setup friction so that you can spend your time analyzing the resulting architecture and controls.

As you work, keep notes on:

- what component each step configures,
- what security purpose it serves,
- what route or behavior it affects.

### *Files on GitHub:*

Starter configuration files for this assignment are available in the course GitHub repository. You may download the ZIP archive or the individual files from within your Linux sandbox. These files are provided as a scaffold to help you build the environment efficiently

[https://github.com/drcjhu/JHU\\_WebSec\\_ZT\\_ID\\_Module](https://github.com/drcjhu/JHU_WebSec_ZT_ID_Module)

## A. CONFIGURE DOCKER COMPOSE YAML FILE

Authelia is a IAM or Identity Access Management tool that adds 2FA capabilities (defense in depth) for externally facing applications. This is especially useful for securement of CI4A, when applications do not come with a predefined security control. This acts as a layer of protection, just as HTTPS does with HTTP.

1. First let's make a directory where we know we can load files into. It's usually good practice to download and install files into the /tmp/ directory so you don't clutter your home (~) directory. For now make a folder in your home directory.  
\$ mkdir IDZT  
\$ cd IDZT/
2. Download the base docker-compose.yml
3. Carefully read over the document and make the necessary changes to the password to secure your Docker containers.
4. Now let's make an authelia folder and a config folder within it.  
\$ mkdir authelia/  
\$ cd authelia/

## JHU WebSec Identity Management and Zero Trust Assignment

```
$ mkdir config/
```

```
$ cd config/
```

5. Within the config, we need to define two files that authelia expects. Without either of these files authelia may fail to start or go into an infinite start loop. Copy the starter files from the Assignment page. Edit both with your favorite editor, in this case I am using Neovim.

Remember if your user is not added to the Docker group you must run the commands with sudo.

```
$ sudo nvim configuration.yml
```

6. Now let's create an argon2 hash of a selected password. This will replace the password in the password field of users\_database.yml. When replacing this make sure you surround it with quotes.

```
$ docker run --rm authelia/authelia:latest authelia crypto hash generate argon2  
--password <PASSWORD_OF_CHOICE>
```

```
$ sudo nvim users_database.yml
```

7. Once completed run the following command to compose your Docker environment. Please give this time as it needs to download all the defined docker images.

```
$ docker compose up
```

```
$ docker ps
```

8. You should see your containers running, however, you still need to configure your reverse proxy. In your browser visit <http://127.0.0.1:81/nginx/proxy> to set your admin account.

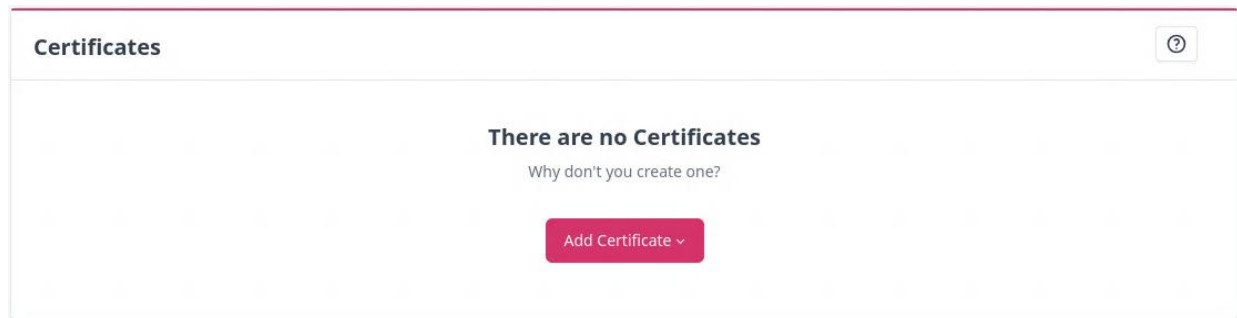
9. After the creation of your account, now you're about to create sites, you may recognize that we need certificates for HTTPS. Let's get to the creation of certificates for HTTPS, (or use the certs from the previous module.) You can generate new ones with the following commands. They should be familiar from a previous module!

```
$ openssl req -x509 -nodes -days 3650 -newkey rsa:2048 -keyout auth.key -out  
auth.crt -subj "/CN=auth.home.local"
```

# JHU WebSec Identity Management and Zero Trust Assignment

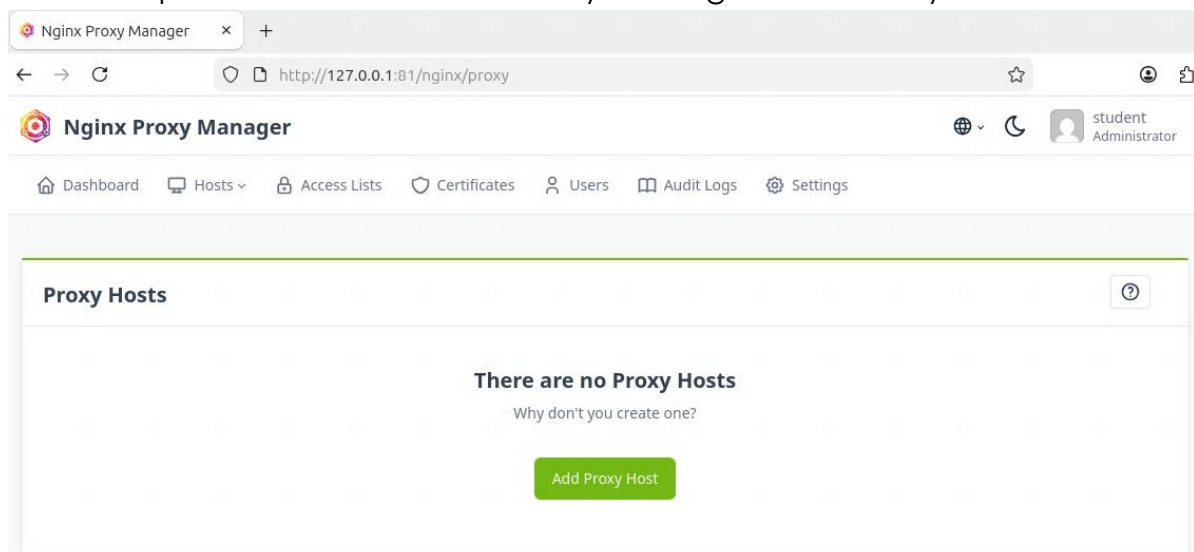
```
$ openssl req -x509 -nodes -days 3650 -newkey rsa:2048 -keyout blog.key -out  
blog.crt -subj "/CN=blog.home.local"
```

```
$ openssl req -x509 -nodes -days 3650 -newkey rsa:2048 -keyout admin.key -out  
admin.crt -subj "/CN=admin.home.local"
```



Navigate to the Certificates tab in your Nginx Proxy Manager page and click Add Certificate. Select Custom certificate and then provide an appropriate name. Then navigate to your Certificate Key and Certificate files. Do this for each of the generated certificates.

10. Next let's put the certificates to use by clicking on Add Proxy Host





11. Now we must define the domains that we wish to deploy in our environment.

**Add Proxy Host**

Details Custom Locations SSL

Domain Names

blog.home.local x

Scheme Forward Hostname / IP Forward Port

http ghost 2368

Access List

Publicly Accessible

**Options**

Cache Assets

Block Common Exploits

Websockets Support

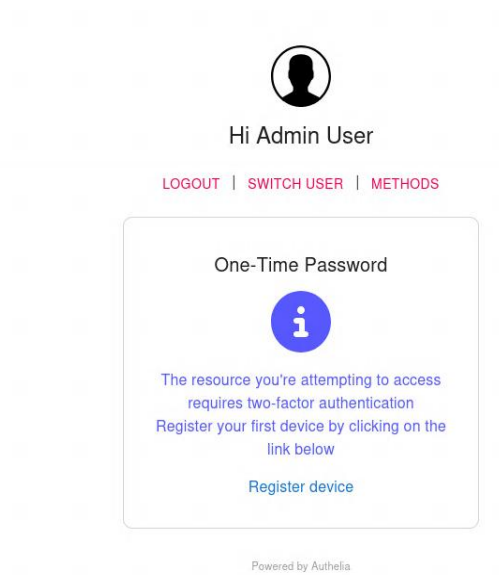
Cancel Save

12. Then select your corresponding SSL certificate for the target domain under the SSL tab then click save. Enable Force SSL, HTTP/2 Support, HSTS Enabled, and HSTS Sub-domains.

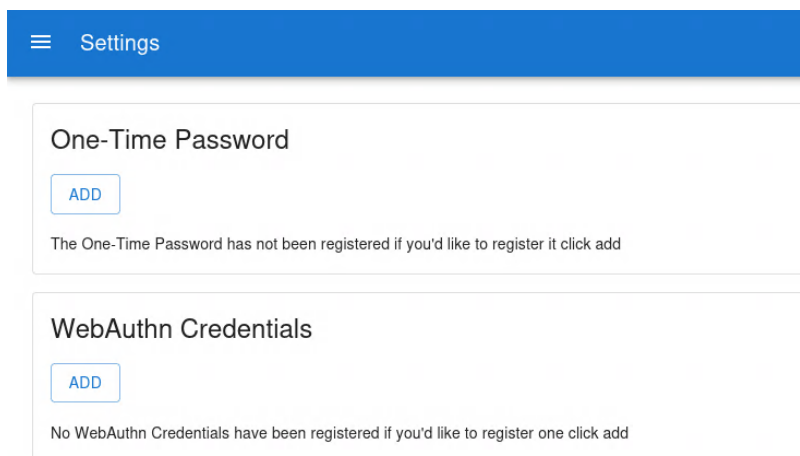
**Reflection point:** Think about what do each of these features do?

13. For the site admin.home.local, which is used to manage our blog, we must add a custom configuration to redirect to authelia's IAM. Use the script provided and paste it into the Advanced Settings (cog wheel) in the Proxy Host settings.

14. When logging in for the first time to auth.home.local. You will be asked to register a device.



Click register device, then click "One-Time Password".



Since this is a local install E-mail is not configured so we have to run the command below to obtain our OTP.

```
$ sudo cat ~/authelia/authelia/config/notification.txt
```

# JHU WebSec Identity Management and Zero Trust Assignment

```
student@student:~/ModIAM/authelia/config$ sudo cat ~/ModIAM/authelia/config/notification.txt
Date: 2026-02-25 21:55:23.966942276 -0500 EST m=+775175.363662705
Recipient: {Admin User admin@home.local}
Subject: Confirm your identity
A ONE-TIME CODE HAS BEEN GENERATED TO COMPLETE A REQUESTED ACTION

Hi Admin User,

This notification has been sent to you in order to verify your identity to
change security details for your account at home.local.

Do not share this notification or the content of this notification with anyone.

The following one-time code should only be used in the prompt displayed in your
browser.

-----
8V9AZWZX
-----
```

15. The Register One-Time Password window will appear to help you register your application. Click Next and scan the QR code to register your device.

### Register One-Time Password

This dialog handles registration of a One-Time Password

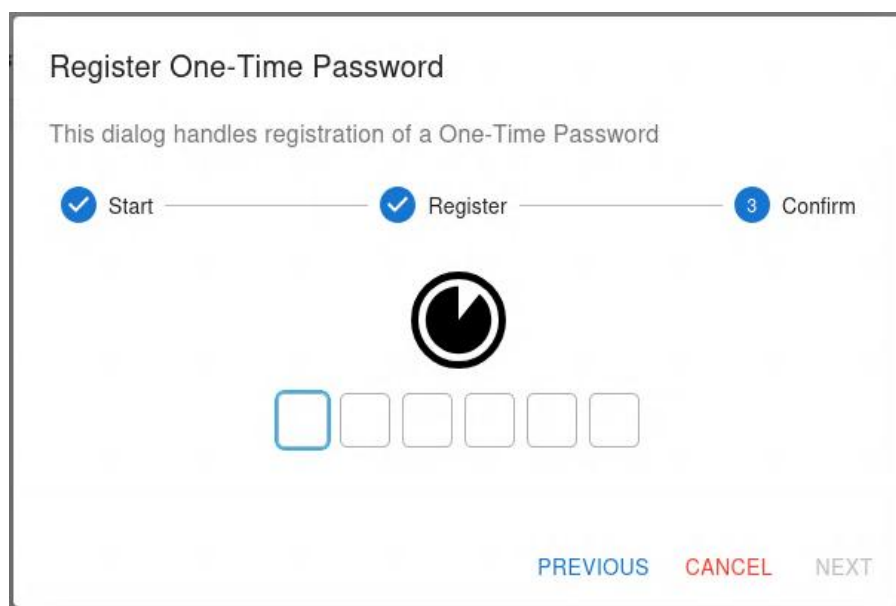
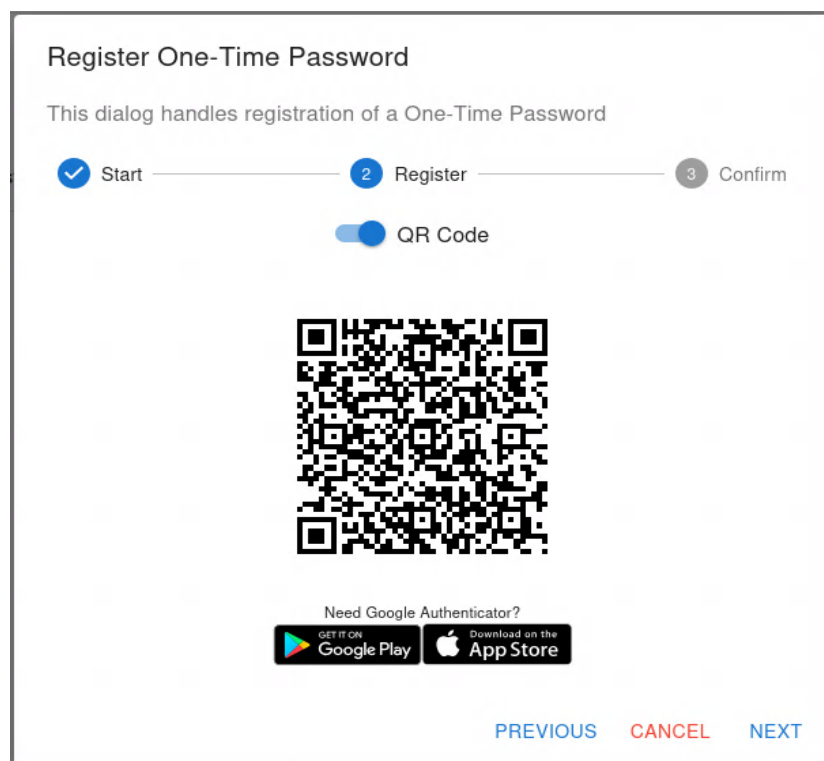
1 Start

2 Register

3 Confirm

To begin select next

PREVIOUS CANCEL NEXT



The final window will request you enter a OTP to login.

16. After configuring your one time password, when you visit `admin.home.local`, you should be redirected to an Authelia page to verify your identity then be able to log in to Ghost.

## JHU WebSec Identity Management and Zero Trust Assignment

When visiting `auth.home.local`, you will be directed into the Authelia admin page. Finally if you'd like to see your blog page you can visit `blog.home.local`.

**Reflection Point:** Consider what happens when you visit `blog.home.local/ghost`.

17. Let's fix this vulnerability by preventing users from accessing this site. Go back to NPM and click edit. Click Advanced Settings (cog wheel) and add the `ghostBlock.config` code.

**Reflection Point:** Now try to visit `blog.home.local/ghost`, do you see what happens now?

### Grading Rubric

| Criterion                              | Points | Competent, 100%                                                                                                                                                                                                 | Sufficient, 80%                                                                                                                                                                   | Unsatisfactory, 0%                                                                                                                       |
|----------------------------------------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| Environment Summary                    | 10     | Clearly and accurately describes the deployed stack and the role of the reverse proxy, identity layer, containerized application, TLS or certificate support, and MFA mechanism.                                | Describes most major components correctly, but one or more roles are vague, incomplete, or only partially accurate.                                                               | Fails to describe the environment clearly, omits major components, or shows significant misunderstanding of the stack.                   |
| Initial Exposure and Trust Assumptions | 15     | Clearly identifies the protected asset, route, or function and explains the original trust assumption and why it is weak from a Zero Trust perspective. Demonstrates strong understanding of exposure and risk. | Identifies the protected asset or route and provides a basic explanation of the trust assumption, but analysis is incomplete, generic, or only partially connected to Zero Trust. | Does not clearly identify the protected asset or route, or fails to explain the original trust assumption and its security significance. |
| Identity and Access Design             | 20     | Clearly explains how the design handles authentication, MFA, route protection, and any path, role, or privilege distinctions. Shows thoughtful application of Zero Trust principles to the architecture.        | Explains most design elements correctly, but discussion of authentication, authorization, MFA, or route protection is incomplete, shallow, or uneven.                             | Does not explain the identity and access design adequately, or shows major misunderstanding of how the controls operate.                 |

# JHU WebSec Identity Management and Zero Trust Assignment

| Criterion                             | Points     | Competent, 100%                                                                                                                                                                                                                               | Sufficient, 80%                                                                                                                                               | Unsatisfactory, 0%                                                                                            |
|---------------------------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>Evidence and Observed Behavior</b> | <b>20</b>  | Provides clear, relevant, and well-annotated screenshots or logs showing successful access, denied or redirected access, identity verification or MFA, and the before and after behavior of the /ghost path. Evidence is well tied to claims. | Provides most required evidence, but some screenshots, logs, or annotations are missing, unclear, weakly explained, or not clearly connected to the analysis. | Evidence is missing, insufficient, unannotated, or does not demonstrate the required behaviors.               |
| <b>AAA and CI4A Analysis</b>          | <b>20</b>  | Clearly applies Authentication, Authorization, and Accounting, and relates the implementation to CI4A in a way that is specific to the student's design. Analysis goes beyond definitions and demonstrates real security reasoning.           | Addresses AAA and CI4A, but discussion is mostly descriptive, partially generic, or only loosely connected to the implemented design.                         | Fails to meaningfully apply AAA or CI4A, or provides only inaccurate, generic, or minimal discussion.         |
| <b>Residual Risk and Improvement</b>  | <b>10</b>  | Identifies two meaningful residual risks or limitations and explains why each matters. Proposes realistic and relevant improvements. Demonstrates mature security judgment.                                                                   | Identifies at least one or two weaknesses, but explanation of impact or improvements is limited, generic, or only partly convincing.                          | Fails to identify meaningful residual risks, or proposed improvements are missing, irrelevant, or inaccurate. |
| <b>Focused Analysis Question</b>      | <b>5</b>   | Answers the selected question directly, clearly, and with strong reasoning tied to the student's environment and observations.                                                                                                                | Answers the selected question, but response is brief, partially developed, or only loosely tied to the environment and evidence.                              | Does not answer the selected question adequately, or response is unclear, off topic, or unsupported.          |
| <b>Total</b>                          | <b>100</b> |                                                                                                                                                                                                                                               |                                                                                                                                                               |                                                                                                               |

[End of Document.]